Nighat Medical Complex Administrative AI Integration

Implemented and locally tested
External AI: DISABLED
Live inference: NOT VERIFIED

1. Outcome and activation status

A modular Gemini API adapter now exists in the actual patient conversation path. It can interpret general administrative messages, select approved clinic information, recognize appointment intentions and use a prior topic for follow-ups. The existing appointment state machine, MongoDB services, website design and admin portal are preserved.

The user explicitly requested: "Keep external AI disabled until privacy review is complete." Accordingly, AI_ENABLED, AI_PRIVACY_APPROVED and AI_PAID_SERVICE_CONFIRMED remain false; the inspected AI key is empty. No real Gemini request, live inference, production patient write or outbound WhatsApp delivery was performed during this implementation. The report does not treat synthetic responses as successful Google inference.

Provider implementation	Google Gemini Developer API, backend only
Proposed model	gemini-3.8-flash; stable model documented by Google
Model availability	Documented support verified; account access NOT VERIFIED
API endpoint	https://generativelanguage.googleapis.com/v1beta/models/{AI_MODEL}:generateContent
Credentials	AI_API_KEY, never in frontend or URL query strings
Live inference evidence	None; not attempted because privacy review is pending
Local testing	12 AI integration groups; 24 existing backend groups; 7 new browser groups; 7 existing browser groups; frontend build passed
Clinical scope	Administrative information and booking only; no diagnosis, prescribing or medical advice

This report supersedes the implementation-state portion of the prior AI API audit. See AI_INTEGRATION.md in the project root for full configuration and operating instructions.

2. Response flow and trust boundaries

Website -> POST /api/staff/chat/message -> staff controller -> shared conversation engine -> consent/privacy gates -> administrative AI interpreter -> Gemini adapter -> validated JSON response plan -> backend fact renderer -> existing chat UI.

Model responsibilities	Semantic intent/language interpretation, follow-up topic use, selection of approved fact IDs.
Backend responsibilities	Read the real schedule; calculate actual slots; validate name/phone; save, reschedule and cancel bookings; enforce unique reservations and confirmation steps.
Model output contract	Exactly intent, language, topic and at most two approved fact IDs. Unknown fields, IDs and intents are rejected.
Factual output	Server renders approved stored values with curated English, Urdu and Roman Urdu conversational text. Arbitrary LLM-generated medical prose is never displayed.
Workflow isolation	No model request during active booking/manage workflows, or for explicit menu/date/slot/confirmation payloads.
Safe fallback	Existing menus and deterministic booking continue when AI is disabled, declined or unavailable. Unknown general questions receive a safe staff/menu response.

This is a constrained AI-assisted response planner, not an unrestricted generative medical chatbot. Approved facts retain their stored wording; names, qualifications and some schedule labels remain Latin/English even when the conversational introduction is Urdu or Roman Urdu.

The LLM can start a booking workflow, but cannot jump past name, phone, date, actual slot, review or confirmation. A request to cancel/manage starts the existing backend workflow rather than executing the model output.

Source evidence: backend/services/conversationEngine.js:220; backend/services/conversationEngine.js:396; backend/services/ai/assistant.js:48; backend/services/ai/assistant.js:71; backend/services/ai/provider.js:60.

3. Verified clinic knowledge

The integration reuses the approved MongoDB knowledge record keyed nighat_medical_complex. It does not seed new production doctor or schedule data. The active configured physician remains Dr. Khurram Mansoor, ID dr-khurram; MBBS, PGR (FCPS Gynae & Obs), Member of PSASM; Monday-Friday 09:00-12:30 Asia/Karachi, seven-minute duration. The PGR designation is not presented as completed FCPS consultant/specialist status.

The approved snapshot filters inactive/unverified items. Only bounded public facts and FAQs are forwarded; internal assistant instructions and patient records are excluded. Actual appointment availability is still calculated by the backend and never inferred by Gemini. Source: backend/services/knowledgeService.js:13; backend/services/knowledgeService.js:18; backend/services/ai/assistant.js:41.

4. Privacy controls and external data

Operator gate	AI_ENABLED=true, AI_PRIVACY_APPROVED=true and AI_PAID_SERVICE_CONFIRMED=true, plus a configured key, are all required.
Patient choice	A configured general chat first displays the Google Gemini disclosure. No message goes to the provider until the session opts in. Decline retains menu booking.
Withdrawal	Use the external-AI opt-out option or type disable external ai. Consent choice/time is stored in StaffMessage.
Current-message minimization	At most 800 characters, with limited removal of known session identities, numbers, emails, URLs, reference IDs and common name/address introductions.
Additional request context	Language hint, prior administrative topic enum and bounded approved public facts/FAQs; administrative instructions and response schema.
Never forwarded by design	Raw history, session IDs, appointment/patient records, booking fields, uploads, internal assistant instructions, database credentials.
Medical/privacy filtering	Recognized diagnosis, prescribing, sensitive medical, record-access and prompt-injection requests are handled locally without provider transfer.

Redaction is heuristic, not guaranteed anonymization. A person could put an unknown name or health detail in general chat. The patient disclosure warns against this; operator review must assess retention, paid-service processing terms, region, logging/sharing settings, consent and applicable privacy obligations before activation. No clinical or legal compliance certification is claimed.

The adapter stores only nonsecret response provenance in message metadata: provider/model, response ID, token counts and topic. Raw provider bodies/prompts are not logged by the adapter. Conversation messages remain subject to the application's existing local storage/retention policies.

Chat-history recovery no longer falls back to a phone number: requests need the private session token; object-shaped query injection is rejected. New browser and server session IDs use cryptographic randomness. Existing session IDs are retained for compatibility and remain bearer secrets.

Evidence: backend/services/ai/provider.js:16; backend/services/ai/assistant.js:30; backend/services/ai/assistant.js:24; backend/services/conversationEngine.js:317; backend/models/StaffMessage.js:75; backend/controllers/staffController.js:254; frontend/patient/app.js:47.

5. Provider terms and model documentation

Official Google model/deprecation documentation inspected on 6 November 2026 lists gemini-3.8-flash as stable with no announced shutdown date. That does not prove this account can use it. Google's current service terms and retention guidance must be reviewed directly; this implementation is restricted to administrative use, not clinical practice or professional medical advice.

Primary references: https://ai.google.dev/gemini-api/docs/models ; https://ai.google.dev/gemini-api/docs/deprecations ; https://ai.google.dev/gemini-api/terms ; https://ai.google.dev/gemini-api/docs/zdr .

6. Reliability and API configuration

Configuration variables	AI_PROVIDER, AI_MODEL, AI_API_KEY, AI_ENABLED, AI_PRIVACY_APPROVED, AI_PAID_SERVICE_CONFIRMED, AI_TIMEOUT_MS, AI_MAX_RETRIES.
Current configuration	gemini / gemini-3.8-flash; empty key; all activation/privacy flags false.
Timeouts	6 seconds per attempt by default, at most 8 seconds configurable; total request deadline 12 seconds.
Retries	At most one retry for 429/5xx; authentication/model errors are not retried.
Concurrency/circuit	Two concurrent calls per backend process; 30-second open circuit after repeated failures.
Abuse control	Public chat POST rate limited to 30 requests/minute/IP; multi-instance shared limiting is not implemented.
Transport security	Fixed Google HTTPS origin, key in x-goog-api-key header, redirects refused; no arbitrary endpoint setting.
Readiness route	Admin-authenticated GET /api/knowledge/ai-status shows safe configuration information, not an asserted live inference result.

Source: backend/services/ai/provider.js:24; backend/services/ai/provider.js:76; backend/routes/staffRoutes.js:20; backend/routes/knowledgeRoutes.js:7.

7. WhatsApp compatibility and webhook security

Website and WhatsApp share the same interpreter, privacy gates and deterministic booking engine. Incoming interactive IDs now pass from Meta metadata.payload into processConversationMessage.payload. Outgoing response metadata now retains option IDs so the WhatsApp adapter can build interactive messages.

Webhook POSTs must have a valid HMAC-SHA256 X-Hub-Signature-256 computed over exact raw bytes. The raw body is captured by the JSON parser verification hook. Missing/placeholder app secrets, malformed or missing signatures, and altered payloads fail closed with 403. The verification handshake needs an explicitly configured token, which is no longer printed on mismatch. The lead simulator now requires admin authentication.

Outbound WhatsApp delivery remains gated by WHATSAPP_DELIVERY_ENABLED=false. Real Meta credentials, phone-number ID, HTTPS webhook setup and a signed sandbox delivery test remain required. No outbound WhatsApp message was sent. Existing in-memory duplicate-event handling is not a durable multi-instance delivery guarantee.

Source: backend/services/leadAiService.js:14; backend/services/leadAiService.js:8; backend/services/metaWebhookService.js:32; backend/controllers/leadController.js:34; backend/server.js:41; backend/services/metaWebhookService.js:214.

8. Tests and evidence

12 new AI integration groups	Synthetic local HTTP serialization and model-capability contract; redaction; strict output validation; local safety; consent; multilingual plans; natural booking handoff with real MongoDB write; WhatsApp payload/options; exact-body HMAC; authentication failures; retry, timeout and circuit behavior.
13 booking regression groups	Verified physician and 30-slot schedule, weekends, constraints/overrides, unchanged conflicting history, idempotent persistence, separate-process collision prevention, cancellation/rescheduling, multilingual booking starts and WhatsApp source.
11 knowledge regression groups	Approved facts, unknown information, verified scheduling, real booking/idempotency, medical/handover behavior and disconnected/reconnected database handling.
7 new Chrome groups	30 actual backend slots, explicit consent, natural requests/follow-up topic, English/Urdu/Roman Urdu, local medical refusal, database-backed confirmed booking, scoped chat history and four responsive widths.
7 existing Chrome groups	Form collision recovery, real form booking, English chat pagination/booking, refresh persistence, full Urdu booking, admin reschedule/cancel and seven responsive widths.
Frontend build	Passed; existing classic-script bundling warnings remain.
Live Gemini inference	NOT ATTEMPTED. No authentication test and no successful inference evidence.
Production writes	No production patient/appointment/knowledge records created or changed by these tests.

All model responses in local tests are synthetic. The request adapter performs real HTTP serialization to a loopback test server; that proves request construction and control flow, not Google model reasoning, language quality or account access. The browser test preload refuses any nonlocal test database and redirects only the fixed Google API origin to its synthetic loopback transport.

A nondeterministic assertion in the older concurrency test was corrected: the idempotent retry now uses the actual winning request's patient details instead of assuming which concurrent caller won. This fixes the test expectation without altering booking logic.

Evidence files/scripts: backend/tests/test_ai_integration.js; backend/tests/test_ai_browser.cjs; backend/tests/test_khurram_booking.js; backend/tests/test_nighat_knowledge.js; .qa/ai-browser-results.json; .qa/khurram-browser-results.json. Synthetic records are isolated locally and cleaned up.

9. Live verification procedure

Only after privacy approval, valid paid-service credentials and explicit activation, run: node backend/scripts/verifyAi.js --live-synthetic . The script checks model support, requests a synthetic JSON connectivity result, validates it and saves nonsecret response provenance to ignored .qa/ai-live-evidence.json. It exits nonzero on failed setup, authentication, unavailable models or invalid inference. No such successful evidence file was produced during this task. Source: backend/scripts/verifyAi.js:8.

10. Remaining setup and rollout limits

External AI remains intentionally OFF, matching the user's explicit instruction. A valid API key has not been supplied. Live Google inference, real-model English/Urdu/Roman Urdu quality, real-model natural intent accuracy and signed Meta sandbox delivery are unverified. Do not mark this as an activated or production-verified AI service.

Before enabling Gemini	Complete privacy/processing review; configure a valid key for an appropriate paid-service project; explicitly enable the three gates; restart the backend.
Before claiming live success	Run the synthetic live probe; require valid JSON output and model response provenance. Evaluate representative synthetic multilingual prompts and failure behavior.
Before public WhatsApp	Use real nonplaceholder Meta settings, HTTPS webhook registration, valid signed sandbox events and successful test delivery; explicitly enable delivery only after review.
Broader patient authorization	Legacy public appointment search/management endpoints still use phone/reference lookup rather than complete patient login/OTP authorization. The model cannot access them; review and harden these before public exposure.
Broader deployment hardening	Review existing admin defaults/authentication, CORS, TLS, logs/retention, persistent webhook event handling and multi-instance rate/circuit coordination. This integration is not a full application security certification.

The new safeguards prevent model-driven disclosure and remove phone-only chat-history recovery. They do not retroactively establish ownership checks for every legacy application endpoint. This material limitation is documented instead of being hidden behind the AI integration status.

11. Files changed

New implementation: backend/services/ai/provider.js; backend/services/ai/assistant.js; backend/scripts/verifyAi.js. Integration: conversationEngine.js, knowledgeService.js, leadAiService.js, metaWebhookService.js, staffController.js, leadController.js, server.js, StaffMessage.js, knowledgeRoutes.js, staffRoutes.js and leadRoutes.js. Configuration: backend/.env.example and nonsecret AI gates in ignored backend/.env; MongoDB settings preserved. Frontend: cryptographic new-session generation only; no design/style changes. Tests: new AI integration/browser suite and synthetic transport fixture; concurrency-test assertion correction. Documentation: AI_INTEGRATION.md and this PDF.

12. Final technical conclusion

The project now contains a real modular Gemini API implementation in its conversation path, guarded by operator privacy controls, patient consent, strict fact selection and backend-owned actions. Local synthetic transport, security, browser and database booking tests passed. The existing deterministic booking system continues to function with AI off.

> **Activation is pending. External AI was not enabled and no successful live inference is claimed. Privacy approval, a valid API key, account-level model verification and real-provider evaluation remain necessary.**